



PERFORMANCE WORK STATEMENT DEPARTMENT OF VETERANS AFFAIRS

**Office of Information & Technology
Information Technology Budget and Finance**

**Budget and Acquisition Management Software as a
Service Solution and Maintenance**

Date: 3/4/2025

36C10A25Q0031

Draft PWS Version Number: 1.0

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

1.0 BACKGROUND

The Department of Veterans Affairs (VA), Office of Information & Technology (OIT), Information Technology Budget and Finance (ITBF) strives to provide high quality, effective, and efficient Information Technology (IT) services to those responsible for providing care to the Veterans at the point-of-care as well as throughout all the points of the Veterans' health care in an effective, timely and compassionate manner. VA depends on Information Management/Information Technology (IM/IT) systems to meet mission goals.

OIT requires the capability to manage the Congressional appropriations and its acquisitions to enhance financial and acquisition data tracking, transparency, and traceability across OIT portfolios and investments. This capability reinforces OIT's commitment to effective fiscal management while adhering to the stringent requirements set forth by federal oversight bodies.

2.0 APPLICABLE DOCUMENTS

In the performance of the tasks associated with this Performance Work Statement (PWS), the Contractor shall comply with the following:

1. 44 U.S.C. § 3541-3549, "Federal Information Security Management Act (FISMA) of 2002"
2. "Federal Information Security Modernization Act of 2014"
3. Federal Information Processing Standards (FIPS) Publication 140-2, "Security Requirements for Cryptographic Modules"
4. FIPS Pub 199. "Standards for Security Categorization of Federal Information and Information Systems," February 2004
5. FIPS Pub 200, "Minimum Security Requirements for Federal Information and Information Systems," March 2006
6. FIPS Pub 201-2, "Personal Identity Verification of Federal Employees and Contractors," August 2013
7. 10 U.S.C. § 2224, "Defense Information Assurance Program"
8. 5 U.S.C. § 552a, as amended, "The Privacy Act of 1974"
9. Public Law 109-461, Veterans Benefits, Health Care, and Information Technology Act of 2006, Title IX, Information Security Matters
10. 42 U.S.C. § 2000d "Title VI of the Civil Rights Act of 1964"
11. VA Directive 0710, "Personnel Security and Suitability Program," June 4, 2010, <https://www.va.gov/vapubs/index.cfm>
12. VA Handbook 0710, "Personnel Security and Suitability Program," May 2, 2016, <https://www.va.gov/vapubs/index.cfm>
13. VA Directive and Handbook 6102, "Internet/Intranet Services," August 5, 2019
14. 36 C.F.R. Part 1194 "Information and Communication Technology Standards and Guidelines," January 18, 2017

Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832

15. Office of Management and Budget (OMB) Circular A-130, "Managing Federal Information as a Strategic Resource," July 28, 2016
16. 32 C.F.R. Part 199, "Civilian Health and Medical Program of the Uniformed Services (CHAMPUS)"
17. NIST SP 800-66 Rev. 1, "An Introductory Resource Guide for Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule," October 2008
18. Sections 504 and 508 of the Rehabilitation Act (29 U.S.C. § 794d), as amended, January 18, 2017
19. Homeland Security Presidential Directive (12) (HSPD-12), August 27, 2004
20. VA Directive 6500, "VA Cybersecurity Program," February 24, 2021
21. VA Handbook 6500, "Risk Management Framework for VA Information Systems VA Information Security Program," February 24, 2021
22. VA Handbook 6500.2, "Management of Breaches Involving Sensitive Personal Information (SPI)," March 12, 2019
23. VA Handbook 6500.5, "Incorporating Security and Privacy into the System Development Lifecycle," March 22, 2010
24. VA Handbook 6500.6, "Contract Security," March 12, 2010
25. VA Handbook 6500.8, "Information System Contingency Planning," April 6, 2011
26. VA Handbook 6500.10, "Mobile Device Security Policy," February 15, 2018
27. VA Handbook 6500.11, "VA Firewall Configuration," August 22, 2017
28. OIT Process Asset Library (PAL), <https://www.va.gov/process/> . Reference Process Maps at <https://www.va.gov/process/maps.asp> and Artifact templates at <https://www.va.gov/process/artifacts.asp>
29. One-VA Technical Reference Model (TRM) (reference at <https://www.va.gov/trm/TRMHomePage.aspx>)
30. VA Directive 6508, "Implementation of Privacy Threshold Analysis and Privacy Impact Assessment," October 15, 2014
31. VA Handbook 6508.1, "Procedures for Privacy Threshold Analysis and Privacy Impact Assessment," July 30, 2015
32. VA Handbook 6510, "VA Identity and Access Management," January 15, 2016
33. VA Directive and Handbook 6513, "Secure External Connections," October 12, 2017
34. VA Directive 6300, "Records and Information Management," September 21, 2018
35. VA Handbook, 6300.1, "Records Management Procedures," March 24, 2010
36. NIST SP 800-37 Rev 2, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy," December 2018
37. NIST SP 800-53 Rev. 5, "Security and Privacy Controls for Federal Information Systems and Organizations," September 23, 2020 (includes updates as of 12/10/2020)
38. VA Directive 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," October 26, 2015

Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832

39. VA Handbook 0735, "Homeland Security Presidential Directive 12 (HSPD-12) Program," March 24, 2014
40. OMB Memorandum 05-24, "Implementation of Homeland Security Presidential Directive (HSPD) 12 – Policy for a Common Identification Standard for Federal Employees and Contractors," August 5, 2005
41. OMB Memorandum M-19-17, "Enabling Mission Delivery Through Improved Identity, Credential, and Access Management," May 21, 2019
42. OMB Memorandum, "Guidance for Homeland Security Presidential Directive (HSPD) 12 Implementation," May 23, 2008
43. Federal Identity, Credential, and Access Management (FICAM) Roadmap and Implementation Guidance, December 2, 2011, (NOTE: Part A of the FICAM Roadmap and Implementation Guidance, v2.0, was replaced in 2015 with an updated Architecture (<https://arch.idmanagement.gov/#what-is-the-ficam-architecture>))
44. NIST SP 800-116 Rev 1, "Guidelines for the Use of Personal Identity Verification (PIV) Credentials in Facility Access," June 2018
45. NIST SP 800-63-3, 800-63A, 800-63B, 800-63C, "Digital Identity Guidelines," updated March 02, 2020
46. NIST SP 800-157, "Guidelines for Derived PIV Credentials," December 2014
47. NIST SP 800-164, "Guidelines on Hardware-Rooted Security in Mobile Devices (Draft)," October 2012
48. Draft National Institute of Standards and Technology Interagency Report (NISTIR) 7981, "Mobile, PIV, and Authentication," March 2014
49. VA Memorandum, VAIQ #7100147, "Continued Implementation of Homeland Security Presidential Directive 12 (HSPD-12)," April 29, 2011 (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>)
50. IAM Identity Management Business Requirements Guidance document, May 2013, (reference Enterprise Architecture Section, PIV/IAM (reference <https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514>))
51. VA Memorandum "Personal Identity Verification (PIV) Logical Access Policy Clarification," July 17, 2019, <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>
52. Trusted Internet Connections (TIC) 3.0 Core Guidance Documents, <https://www.cisa.gov/publication/tic-30-core-guidance-documents>
53. OMB Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative," September 12, 2019
54. OMB Memorandum M-08-23, "Securing the Federal Government's Domain Name System Infrastructure," August 22, 2008
55. Sections 524 and 525 of the Energy Independence and Security Act of 2007, (Public Law 110–140), December 19, 2007
56. Section 104 of the Energy Policy Act of 2005, (Public Law 109–58), August 8, 2005
57. Executive Order 13834, "Efficient Federal Operations," dated May 17, 2018
58. Executive Order 13221, "Energy-Efficient Standby Power Devices," August 2, 2001
59. VA Directive 0058, "VA Green Purchasing Program," July 19, 2013

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

60. VA Handbook 0058, "VA Green Purchasing Program," July 19, 2013
61. Office of Information Security (OIS) VAIQ #7424808 Memorandum, "Remote Access," January 15, 2014,
<https://www.voa.va.gov/DocumentListPublic.aspx?NodeId=28>
62. Clinger-Cohen Act of 1996, 40 U.S.C. §11101 and §11103
63. "Veteran Focused Integration Process (VIP) Guide 4.0," January 2021,
<https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371>
64. VA Memorandum "Proper Use of Email and Other Messaging Services," January 2, 2018,
<https://www.voa.va.gov/DocumentListPublic.aspx?NodeId=28>
65. "DevSecOps Product Line Management Playbook" version 2.0, May 2021,
<https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>
66. NIST SP 500-267B Revision 1, "USGv6 Profile," November 2020
67. OMB Memorandum M-21-07, "Completing the Transition to Internet Protocol Version 6 (IPv6)," November 19, 2020
68. Social Security Number (SSN) Fraud Prevention Act of 2017
69. Section 240 of the Consolidated Appropriations Act (CAA) 2018, March 23, 2018

3.0 SCOPE OF WORK

The VA requires a comprehensive Software as a Service (SaaS) solution, to include maintenance, for budget formulation, execution, and acquisition management and oversight functions of the VA OIT Programming, Planning, Budget, and Execution (PPBE) process. The solution needs to enhance financial and acquisition data tracking, transparency, and traceability across OIT portfolios and investments.

The SaaS solution must provide the following functions and capabilities to OIT:

- SaaS platform capability with application solution.
- Implementation including software installation, testing, and deployment support.
- Training support shall be available through the duration of the contract period of performance.
- Help Desk support.
- Service and support including technical support and Service Level Agreements (SLAs).
- Installation of software upgrades, patches, and releases.

4.0 PERFORMANCE DETAILS

4.1 PERFORMANCE PERIOD

The Period of Performance (PoP) shall be 12 months from date of award, with four 12-month option periods. The overall Period of Performance shall not exceed 60 months.

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

There are eleven (11) Federal holidays set by law (USC Title 5 Section 6103) that VA follows:

Under current definitions, five are set by date:

New Year's Day	January 1
Juneteenth	June 19
Independence Day	July 4
Veterans Day	November 11
Christmas Day	December 25

If any of the above falls on a Saturday, then Friday shall be observed as a holiday. Similarly, if one falls on a Sunday, then Monday shall be observed as a holiday.

The other six are set by a day of the week and month:

Martin Luther King's Birthday	Third Monday in January
Washington's Birthday	Third Monday in February
Memorial Day	Last Monday in May
Labor Day	First Monday in September
Columbus Day	Second Monday in October
Thanksgiving	Fourth Thursday in November

4.2 PLACE OF PERFORMANCE

Tasks under this PWS shall be performed at Contractor facilities. The Contractor shall identify the Contractor's place of performance in their proposal submission.

Work may be performed at remote locations with prior approval of the Program Manager (PM). The Contractor shall maintain onsite presence during normal Monday through Friday business hours. After-business-hours, emergency, and pre-approved scheduled work may be performed at remote locations with prior approval of the VA program manager as stated in this PWS.

4.3 TRAVEL

The Government does not anticipate travel for this requirement.

5.0 SPECIFIC TASKS AND DELIVERABLES

5.1 PROJECT MANAGEMENT

5.1.1 CONTRACTOR PROJECT MANAGEMENT PLAN

The Contractor shall deliver a Contractor Project Management Plan (CPMP) that lays out the Contractor's approach, timeline, and tools to be used in execution of the task order. The CPMP should take the form of both a narrative and graphic format that displays the schedule, milestones, risks, and resource support including onboarding of

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

staff. The CPMP shall also include how the Contractor shall coordinate and execute planned, routine, and ad hoc data collection reporting requests as identified within the PWS. The initial baseline CPMP shall be concurred upon and updated in accordance with Section 5.1.1 of the task order. The Contractor shall update and maintain the VA Project Manager (PM) approved CPMP throughout the PoP.

The Contractor shall develop a detailed work plan as a part of the PMP and briefing for the VA project team and Contracting Officer's Representative (COR) to present the Contractor's strategy for performing the work required in this PWS. The Contractor's plan shall be responsive to this PWS and shall describe the approach to be used for each aspect of the PWS.

The Contractor shall prepare and provide a risk management plan, as a part of the PMP. Included in the plan, the Contractor shall prepare and maintain a risk register for this project, which identifies and tracks operational and development risks, status, and mitigation strategies. The risk register shall be updated weekly with the current status of risks, and within two business days following the realization of a risk (i.e., when a risk occurs operationally) or the implementation of a risk mitigation action.

The Contractor shall create a Quality Assurance Monitoring Program (QAMP) plan to detail how the Contractor plans to monitor the quality of the SaaS system. The QAMP Plan shall specifically address how the Contractor will monitor updates to the SaaS application administration data and application enhancements to maintain SaaS system integrity.

The Contractor shall attend a virtual Post Award Conference with the Program and Project Managers. This conference shall cover the Contractor's approach to task order performance, the Project Management Plan, contract staffing and key personnel, and the Risk Management Plan. This meeting shall include the COR, Contracting Officer, and Contract Specialist. The Contractor shall observe the acquisition and budgetary nature of this information involved in performing this task order and shall:

1. Prevent disclosure of budgetary information to which it has access.
2. Prevent disclosure of any acquisition and contractual information to which it has access.
3. Require its staff assigned to and those with access to information involved in this task to sign non-disclosure statements provided by the Government.

Deliverable:

- A. Contractor Project Management Plan
- B. QAMP

5.1.2 SCHEDULE MANAGEMENT

The Contractor shall create and maintain an Integrated Project Schedule (IPS) that depicts the full scope of the project and deliverables. The IPS shall include defined

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

activities and all applicable Universal Project Milestones (UPM) for identifying and documenting discrete events necessary to complete the project. The Contractor shall identify task dependencies, estimate task durations, and assign required resources to each task. Any changes to the project schedule shall be reported in the Monthly Progress Report IAW PWS paragraph 5.1.3. The IPS shall clearly identify the critical path for the project. The Contractor shall obtain the necessary data and update the IPS at minimum monthly, or more frequently as required, for generating schedule reports that depict planned versus actual program, product/project performance and critical path.

Deliverable:

A. Integrated Project Schedule and Updates

5.1.3 REPORTING REQUIREMENTS

The Contractor shall provide the COR with Monthly Progress Reports in electronic form in Microsoft Word and Project formats. The report shall include detailed instructions/explanations for each required data element, to ensure that data is accurate and consistent. These reports shall reflect data as of the last day of the preceding Month.

The Monthly Progress Reports shall cover all work completed during the reporting period and work planned for the subsequent reporting period. The report shall also identify any problems that arose and a description of how the problems were resolved. If problems have not been completely resolved, the Contractor shall provide an explanation including their plan and timeframe for resolving the issue. The report shall also include an itemized list of all Information and Communication Technology (ICT) deliverables and their current Section 508 conformance status. The Contractor shall monitor performance against the CPMP and report any deviations. It is expected that the Contractor will keep in communication with VA accordingly so that issues that arise are transparent to both parties to prevent escalation of outstanding issues.

Monthly reports shall include the following items:

1. Description of actions completed in the reporting period.
2. Description of actions planned for the next reporting period.
3. Status of activities as represented on the project plan for this task order.
4. Current assessment of risks and recommendations on risk mitigation.
5. Recommendations for future activities and changes to plans, milestones, schedules, and resources.
6. Program accomplishments and relevant statistics.

The Contractor shall conduct virtual weekly project management meetings with the Government to review system operations and maintenance, updates, risks, design and

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

processing problems, and all other factors that affect daily system operations and future system upgrades and enhancements.

Deliverable:

- A. Monthly Progress Report

5.1.4 RISK MANAGEMENT

The Contractor shall prepare and deliver a Risk Management Plan (RMP) to the Government for approval. The objectives of the RMP are to identify, address, and mitigate risks before they become threats to success or major sources of rework. The Contractor shall also be responsible for:

- Implementing a structured and systematic approach to recognizing risks.
- Analyzing and evaluating risks by identifying the risk sources, impact, and owner, in addition to the probability of the risk occurring.
- Identifying, assessing, and presenting a range of risk response options, including mitigation strategies and solutions to the Government.
- Soliciting input, comments, and guidance from the Government.
- Monitoring and reviewing the implemented risk response options to evaluate whether the risk response achieved the intended result.
- Supporting and participating in risk status reviews/Program Level Risk Management Board as directed by the COR.
- Provide information, recommendations, and support to the Program Level Risk Process.

Deliverables:

- A. Risk Management Plan
- B. Risk Management Report (included in Monthly Progress Report)

5.1.5 KICK-OFF MEETING

Within one business day of the task order award, the Contractor shall contact the COR to request a kick-off meeting. The kick-off meeting will be held at the Government site no later than 10 business days from the date of issuance of the contract/order. The Contractor's Project Manager (Contractor PM), the key personnel, and core team shall attend the meeting. The Contractor must be prepared to discuss the following:

- A high-level management approach that addresses the scope, resources, project assumptions, constraints, task objectives, key milestones, Contractor's project organization and Contract administration, delivery schedule, and deliverables.
- A high-level work plan for all activities that addresses on- and off-site personnel support expected by month.
- Contractor's high-level approach, schedule, and methodology to implementing planned software upgrades during the task order period of performance.
- Contractor's high-level approach and methodology to any new development and implementation efforts.

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

- Contractor's high-level approach and methodology to address risks, security, staffing/ resource issues including any sub-contractors.
- Contractor's high-level approach and methodology to identify and address changes to include application/software, hosting, upgrades and database communications, and Configuration Management issues.
- Identification of Key Personnel, Responsible, Accountable, Consulted, and Informed, and discuss Staffing/Resource Planning at the Technical Kickoff Meeting.

Deliverables:

- A. Meeting Agenda
- B. Briefing Slides
- C. Meeting Minutes

5.1.6 PRIVACY & HIPAA TRAINING

The Contractor shall submit status of VA Privacy and Information Security Awareness training for all individuals engaged on the task. The status reporting shall identify; a single Contractor Security Point of Contract, the names of all personnel engaged on the task, their initial training date for VA Privacy and Information Security training, and their next required training date. This information shall be submitted as part of the Monthly Progress Report.

The Contractor shall submit Talent Management System (TMS) training certificates of completion for VA Privacy and Information Security Awareness training. The Contractor shall also provide VA Privacy and Information Security Awareness Signed Rules of Behavior, and VA Health Insurance Portability and Accountability Act (HIPAA) Certificate of Completion in accordance with Section 9, Training, from Appendix C of the VA Handbook 6500.6, "Contract Security".

Deliverables:

- A. TMS Training Certificates of Completion for VA Privacy and Information Security Awareness Training
- B. VA Privacy and Information Security Awareness Signed Rules of Behavior
- C. VA HIPAA Certificate of Completion

5.2 COMMERCIAL-OFF-THE-SHELF (COTS) SAAS SOLUTION

OIT requires a robust Budget Formulation (BF), Budget Execution, and Acquisition Management software and services solution. This solution will enable OIT to enhance its financial stewardship by promoting greater efficiency, traceability, and transparency in budgeting and acquisition processes, ensuring improved data controls, and aligning with federal financial regulations. By streamlining these critical functions, ITBF will support OIT in making more informed financial decisions, improving transparency, and driving accountability across all phases of the IT budget lifecycle. The following capabilities are key to reinforcing OIT's commitment to effective fiscal management while adhering to the stringent requirements set forth by federal oversight bodies:

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

1. Maintain system, data, and process integration across ITBF Directorates and PPBE workstreams and activities.
2. Maintain system and data interoperability with existing VA solutions that support current processes and associated guidance. For example, for Planning the solution shall support the Annual Integrated Planning Guide (AIPG) and meet evolving VA and OIT and VA Strategic Goals and Objectives. For Multi-Year Programming (MYP), the solution shall support the MYP guidance.
3. ITBF is seeking a comprehensive solution that supports effective system change management and control. The vendor will provide processes for planning and assessment, stakeholder engagement, and risk management to ensure smooth implementation of changes, including those related to data and funding. The solution should include features for continuous monitoring and evaluation, robust documentation and compliance, and effective data governance. Additionally, the solution shall demonstrate a change control process that will present changes to a change control board (CCB) for decision.
4. The solution shall maintain system and data integrity to a common budget hierarchy ensuring consistency and accuracy across financial operations. This practice supports effective budgeting, reporting, and decision-making by aligning all financial data and processes to a standardized structure. Vendors must ensure their solutions facilitate this alignment, providing robust features that enable data management, validation, and compliance with established budget hierarchies.
5. The solution must demonstrate compliance with the Federal Financial Management Improvement Act (FFMIA) for financial systems to ensure that the solution adheres to federal accounting standards, federal financial management system requirements, and the U.S. Standard General Ledger at the transaction level. This compliance enhances the accuracy, reliability, and timeliness of financial information, supporting effective decision-making and accountability. Vendors must ensure their solutions facilitate adherence to these standards, providing robust documentation, audit trails, and reporting capabilities to meet FFMIA requirements along with other laws and regulations referenced in the PWS.

5.2.1 BUDGET FORMULATION CAPABILITIES

OIT requires a solution that ensures the formulation and reporting of the OIT Congressional Budget Justification aligns with the VA strategic goals and performance standards and meets all Office of Management and Budget (OMB) requirements and Congressional mandates.

- Create datasets that captures up to seven fiscal years ahead and up to seven fiscal years prior to the budget year (including budget requests, enacted, and reported obligations), allowing for strategic budgetary decisions and planning projections.
- Create/Modify/View records and lines to formulate dollars down to the Sub-Project Activity level, with budget structure, strategic alignment, and categorical information required for Congressional submission as well as OMB Submission and Passback. This shall include entry and tracking of Full-Time Equivalent (FTE) by organization and by IT investment.

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

- Track all changes made to any field on a BF header record or line with version control, authorized user who made the change, and date of change to maintain complete traceability from start to end of cycle.
- Establish data linkage between Planning Programming Budgeting Execution workstreams and across funding years using a Unique Identifier (UID) to facilitate proper tracking of budget lines between OIT Service Lines ensuring traceability and alignment of funding profiles.
- Ability to update and manage budget structure and display different views of the dataset within the solution. For example, a “hide” and an “archive” function which would enable users to temporarily hide/archive specific sections as needed.
- Analyze and compare budget structure changes across fiscal years to consistency between budgetary values.
- Analyze and compare OMB Submission and President’s Budget amounts from previous and current Budget Year.
- Manage budget scenario builds.
- Incorporate support for the 1:N prioritization.
- Support bulk data uploads to Create/Modify records and lines and narratives from MS Excel spreadsheet.
- A repository for all budget line narratives that can be uploaded and updated in real-time so that changes in justifications between years can be more accurately tracked.
- The ability to create drop down selections for specific sections of budget lines to ensure a space-saving, user-friendly way to structure data consistently, enhancing navigation and maintaining a clean, organized interface.

5.2.1.1 BUDGET FORMULATION REPORTING AND ANALYTICS

The solution shall have reporting mechanisms for federal executives and managers to monitor budget formulation and reporting activities. The solution must be able to, but not be limited to, do the following requirements:

- Ability to create and/or link charts and tables and/or diagrams between different budget formulation products for multiple data streams and budget years.
- Be able to populate/upload and track FTE by Organization and capture FTE by IT investments.
- Develop and maintain standardized reports that can be easily understood by various OIT and VA stakeholders.
- Ability to add complex queries/formulas and data analytical features to better organize and sift through data.
- Ability to export budget data as raw data as well as custom layouts that summarize, sort, reorganize, group, count, total, or average data like MS Excel pivot tables.

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

5.2.2 EXECUTION CAPABILITIES

The Office of Information Technology (OIT) requires a solution that ensures the approved OIT IT budget is executed efficiently, tracking all expenditures, obligations, and adjustments in line with authorized programs and funding levels.

5.2.2.1 BUDGET OPERATING PLAN

The Office of Information and Technology (OIT) requires a solution to support budget execution responsibilities that includes establishing a phased acquisition level Budget Operating Plan (BOP) leveraging MYP/BF data that allows for management of budget execution actions.

Budget Line Item

- Allow for planned dollars for the upcoming Execution year to be laid out by month at various levels of granularity.
- Include the ability to intake and leverage data from MYP/BF and integrate with the accounting system of record which is a Momentum based product.
- Support the creation of a BOP baseline by denoting approved funding for the Execution vs planned and unfunded requirements.
- Align granular level Budget Line Items to acquisition processes and artifacts such as Requisitions and Purchase Order, Requisition Package records, and iFAMS Documents to compare planned, committed, and obligated dollars.
- Connect spend plan items to relevant Budget Formulation items that share key budget structure fields and from which the target value was generated.
- Create snapshots of budget operating plan data at a specific point in time that can be viewed and reported on comparing to current live data.

5.2.2.2 FUNDING CHANGE REQUESTS

- Support a process that facilitates workflows and needed data for funding change requests to the established BOP.
- Support tracking and traceability of Budget Line Items to include but not limited to systems control, upward and downward adjustments, and changes/impacts to Budget Operating Plan.

5.2.2.3 UNFUNDED REQUIREMENT (UFR) TRACKING

- Support the inclusion of Unfunded Requirements in the established BOP as needed to drive the VA Mission.

5.2.2.5 EXECUTION REPORTING AND ANALYTICS

The solution shall have reporting mechanisms for federal executives and managers to monitor budget execution and spending patterns. The solution must be able to, but not be limited to, do the following requirements:

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

- Contain standardized reports for budget execution that can be easily understood by non-financial stakeholders.
- Allow monthly, quarterly, and annual financial reports on obligations and expenditures.
- Include dashboard reporting tools for real-time financial oversight and monitoring (i.e. planned, committed, obligated)
- Provide tool for variance analysis between planned and actual expenditures, highlighting significant deviations.
- Contain reporting capabilities for unobligated funds, reallocations, and any significant changes or risks to budget performance.
- Ensure reports align with Government Performance and Results Act (GPRA) and the Federal Budget.
- Develop a solution to track FTE budget plan and execution by organization or other high-level categories. This would include tracking of FTE by project, organization, Program, etc. This will allow managers to be able to capture the total life-cycle cost of a particular project.

5.2.3 ACQUISITION MANAGEMENT AND COMPLIANCE

The Contractor shall provide a comprehensive acquisition management and reporting tool that has end-to-end functionality for data collection, processing, analysis, and visualization. The acquisition management tool must support the entire procurement lifecycle—from acquisition planning through contract award and closeout that sync real-time status updates with planned, committed, and obligated funding lines. To support maximum adaptability, it must provide flexible business rules, configurable workflows, and an end-to-end electronic file of pre- and post-award documentation.

5.2.3.1 DATA ACQUISITION AND INTEGRATION

The contractor shall provide a solution with the following data acquisition and integration support:

- Real-time and batch data collection options.
- Automated data ingestion and synchronization.
- Data validation and error handling mechanisms.

5.2.3.2 ACQUISITION TRACKING AND MONITORING

The contractor shall provide a solution with tracking functionality to include but not limited to the following:

- Unique identifier assignment for each acquisition project.
- Status tracking with customizable workflow stages.
- Automated email alerts and notifications for key milestones.
- Multi-stakeholder point-of-contact information.
- Contractual details (such as periods of performance, contract order numbers, milestone dates, etc.).

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

- Historical data logging and audit trails.
- Search capabilities that allow users to search for specific records using different fields (i.e. Description, creator, acquisition unique identifier, etc.).

5.2.3.3 DATA PROCESING AND MANAGEMENT

The contractor shall provide a solution with the following data processing and management capabilities:

- Data cleansing, deduplication, and normalization.
- Custom tagging and categorization for easy filtering.
- Role-based access controls and permissions.
- Compliance with industry standards and data security protocols.
- Configurable workflows and approval processes.
- Integration with third-party business intelligence tools.

5.2.3.4 IT ACQUISITION COMPLIANCE SUPPORT

The contractor shall provide a solution that supports the Department's acquisition compliance with the Federal Information Reform Act (FITARA) and Office of Management and Budget (OMB) Memorandum 15-14, Management and Oversight of Federal Information Technology. The solution must be able to meet the following requirements:

- An automated process that allows all VA Administrations and Staff Offices to submit requests for approval of IT equipment/software acquisitions.
- Handling up to 10,000 records per year.
- Allow requests to be submitted and viewed through multiple fiscal years to include the year of execution.
- Restrict editing fields after submission.
- Provide an "undo" function to reverse an error by any approved user for the record.
- Generate an "Approval Document" (Initial and Final) in printable form (PDF).
- Provide an Approval Ledger to track Approval History and reviewer comments.
- Provide a Change History Repository.
- Send out automated email notifications to all users to accomplish a required action.
- Send out automated notifications reminders to users based on specified periods of time.
- Delete/cancel unwanted requests.
- Edit/modify a request after approval.
- Fillable request form that routes for reviews and approvals
- Ability to customize approval routing to different approvers based on dollar thresholds (approvals must be able to route through a minimum of 10 approvers).

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

5.2.3.5 ACQUISITION REPORTING AND ANALYTICS

- Customizable dashboards with real-time metrics.
- Predefined and ad-hoc reporting capabilities.
- Data visualization tools (charts, graphs, trend analysis).
- Export options (PDF, Excel, CSV, API integration).

5.2.4 USER ACCESS AND PERMISSIONS MANAGEMENT

The Contractor shall provide a solution that implements Role Based Access Control (RBAC) with secure user authentication.

- Support Single Sign-ON (SSO) with PIV.
- Users must be assigned roles based on job responsibilities.
- Each role must have predefined access rights to different system resources.
- Support for assigning multiple roles to a user.
- System must maintain an Access Control List (ACL) that includes but is not limited to:
 - Access Control List should be configurable by system administrators.
 - Logs should include identity of the user, timestamps, and actions performed.
 - User assigned roles and designated approver information should be traceable.
 - Provide tools for administrators to view, audit, and adjust user permissions easily.

5.2.5 SYSTEM CAPABILITIES

The Contractor shall provide interfaces and data exchanges between the solution and various applications used throughout OIT. The Contractor shall provide system documentation to include:

1. Identification of Interfaces which may include Operation Concepts (systems involved, volume, frequency, etc.), System Diagrams (hardware, communication, software, user interaction, etc.).
2. Interface definition: Define what must done to interface to an existing system, i.e., specific file formats, timing, data mapping, etc.

The solution shall integrate and share data with the following VA systems, including but not limited to:

- Integrated Financial and Acquisition Management System (iFAMS)- The VA OIT accounting system of record.
- Financial Management System (FMS) via Corporate Data Warehouse (CDW)- The VA legacy core accounting system of record, FMS is no longer compliant with OMB Circulars and there is no way to bring it into compliance. The VA is in

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

the process of migrating to iFAMS. The solution shall integrate with both FMS and iFAMS until the VA has completed migration.

- Forecast of Opportunities and Requirements Center for Excellence Application (FORCE). A Department of Veterans Affairs contract management system of record.
- Integrated Funds Control, Accounting, and Procurement (iFCAP) via CDW- A VA database of procurement information that automates the creation, approval, and payment of VA Forms 1358 and 2237 used by VA offices that have not migrated to iFAMS. The system shall integrate with iFCAP until the VA has completed the migration to iFAMS.
- Decision Lens – The OIT integrated planning software used to bolster financial scenario building and decision-making capabilities.

The solution that is currently in use by VA OIT maintains the following system capabilities. The estimates provided are based on current system capacity and business processes.

	Current (FY25)	FY26 Growth Expected	FY27 Growth Expected	FY28 Growth Expected	FY29 Growth Expected	FY30 Growth Expected
Users, total	5,000	5,300	5,600	5,900	5,200	6,500
Users, regular (2+ times per week)	395	425	450	475	500	525
Users, concurrent	215	225	240	250	260	275
Reports, static (created by developers)	11	11	12	12	12	13
Reports, static (saved by users)	Saved: 4 Number of Runs: 379	Saved: 4 Run: 400	Saved: 4 Run: 400	Saved: 4 Run: 400	Saved: 4 Run: 400	Saved: 4 Run: 400
Reports, ad hoc templates	20	20	21	21	22	22
Reports, ad hoc (created/	Saved: 4,699	Save: 5,000	Save: 5,400	Save: 5,700	Save: 6,000	Save: 6,400

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

saved by users)	Schedule: d: 281 Runs: 49,652	Schedule: 290 Runs: 51,000	Schedule: 300 Runs: 55,000	Schedule: 315 Runs: 60,000	Schedule: 325 Runs: 62,000	Schedule: 340 Runs: 65,000
Dashboard components	11	11	11	11	11	11
Database Tables	444	460	480	500	520	540
Interfaces with related applications	6	6	6	7	7	7
Power BI Data Models	4	4	5	5	6	6
Power BI Reports (SAIC built and maintained)	8	17	25	31	36	40
Power BI Reports Total	13	22	32	40	47	53

Data accurate as of 02/25/2025

5.2.6 IMPLEMENTATION AND DEPLOYMENT

During the base period, the Contractor shall complete requirements sessions with the VA OIT business customer, users, and OIT staff (hereinafter "VA Team") to properly understand and refine business requirements for implementation. The outcome shall be a review of VA business customer needs.

Deliverables:

- A. Requirements Session Meeting Notes

5.2.6.1 DESIGN

The Contractor shall ensure that the design includes software configurations, interface specifications, screen and report designs, and security control specifications. The design document shall reflect the physical, functional, and operational architecture of the Contractor's solution including constraints to functionality and any gaps. The system/software information shall be captured in the System/Software Design Document (SDD). The SDD shall address the following:

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

1. Establish the system architecture to include key interfaces between the cloud application and VA systems.
2. Include design considerations for security and audit procedures, archival of historical data, data migration and data handling criteria, scheduling, disaster recovery, and quality assurance factors.
3. Identify, define, and design capacity and performance requirements and any associated limitations. Specifically, coordinate with the Government to identify limitations and considerations during the design phase.
4. Apply VA standards complying with security requirements, enterprise architecture, data standardization, format, transmission, and storage in adherence with VA standards identified in the One-VA Technical Reference Model (TRM).

Deliverables:

- A. System Design Document (SDD)

5.2.6.2 CONFIGURATION & IMPLEMENTATION

The Contractor shall provide application configuration services that are consistent with its standard implementation and deployment methodology. The Contractor shall configure the application to meet all VA's requirements as stipulated in this PWS. The Contractor shall provide guidance on alternative approaches to minimize future customizations of the application. The Contractor shall perform all configuration of the systems prior to deployment. The Contractor shall prepare a Change and Configuration Management Plan in accordance with all applicable regulatory policy and guidance. The Change and Configuration Management Plan shall contain all information relevant to defining and modifying the application from the initial baseline configuration and subsequent re-baselining activities.

Deliverables:

- A. Change and Configuration Management Plan

5.2.6.3 PROVIDE NETWORK CONNECTIVITY

The Contractor's hosted cloud environment shall have established and approved direct access to the VA Trusted Internet Connection (TIC) 2.0 Gateway Connection by the Kick-Off Meeting (within 10 days of award). Connectivity between the Cloud Service Provider (CSP) and the VA TIC shall comply with TIC Reference Architecture Document Version 2.0. The Contractor shall not send or receive data to the VA network without an approved Authority to Operate (ATO) from the VA. Any deployment outside of the VA firewall is subject to VA TIC 2.0 Gateway Connection requirements for communication with other VA systems within the VA Firewall.

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

The Contractor shall provide network solutions for connectivity between the primary and secondary site, subject to Federal Information Processing Standard (FIPS)-140-2 certification of equipment and configurations and the criteria set forth by the System Security Plan (SSP).

The Contractor shall deliver the following network functionality:

1. Provide network connectivity that complies with FIPS 140-2, Section 1, Table 1, up to and including Security Level 3.
2. The Contractor solution shall support Internet Protocol Version 6 (IPv6) in accordance with the directive issued by the Office of Management and Budget (OMB) on September 28, 2010, IPv6 technology, in accordance with the USGv6: "Technical Infrastructure for IPv6 Adoption" and the NIST SP 800 series applicable compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices shall support dual stack connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g. web, email, DNS, ISP services, etc.) shall support native IPv6 users, and all internal infrastructure and applications shall communicate using native IPv6 operations.
3. All user connectivity to the cloud hosting environment shall be through the TIC gateway. Role Holders shall not be capable of accessing the Case Management System or background investigation data through an internet connection direct to the cloud that bypasses the TIC gateway.
4. The Contractor shall provide a Service Level Agreement (SLA) document identifying the expected availability of the application. Availability of 99.9 percent is required, with a maximum amount of unplanned downtime per year not to exceed 8 hours.

5.2.6.4 IMPLEMENTATION REVIEW AND SOFTWARE ADOPTION

1. "Go live:" Where appropriate, the Contractor team and the VA core team shall designate a date or time by which the SaaS solution will be fully implemented into the process, including the replacement and retirement of any existing spreadsheets or systems. Following successful completion of the implementation, the Contractor shall update and finalize software configuration, materials, manuals, and user guides, and make final, formal delivery to VA. The Contractor shall support and coordinate the release with the technical staff and resolve issues and ensure that deployment is completed as planned.
2. Implementation Review: The Contractor team and the VA core team shall conduct an evaluation of the quality of the implementation and deployment and capture the value realized using the SaaS software. The teams will also

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

discuss the next steps and improvements, outlining a plan to ensure full adoption of the SaaS software.

3. Documentation: The Contractor shall provide a Post Implementation Report and a Post Deployment Report. The Post Implementation Report shall include the expected outcomes as specified in the Implementation Plan, reports on variances from that plan and then asks for recommendations and how they will be used, as well as lessons learned. The Post Deployment Report shall include a comparison for actual versus expected levels of performance and support, a review of product support, product improvements incorporated, and configuration control. If any issues that affect system performance are detailed in the Post Implementation Report or the Post Deployment Report, the Contractor shall also provide a Software Remediation Plan. The Plan shall include a list of the steps to be taken to address the issue, who will be responsible for each step, a timeline for completing each step, methodologies for measuring progress and determining when the remediation project is complete.

Deliverable:

- A. Post Implementation Report

5.2.7 TRAINING

The Contractor shall provide user training. The Contractor shall update the existing, computer-based training modules for the solution as needed with each release to ensure training information reflects the current version of all system modules. The training modules shall be electronically addressed to end users of the system and to management and executive level users. The training packages shall be succinct, clear, and shall be tested on knowledgeable users prior to release to new users. The Contractor shall develop and provide training documentation to include a training guide, user materials, and quick reference cards to be used during training. These materials shall be made available to all users electronically. The Contractor shall modify training instruction and documentation as system updates and enhancements are implemented.

Deliverables:

- A. Updated Computer-Based Training Modules
- B. User Manuals
- C. Quick Reference Card for users

5.2.8 HELP DESK

The Contractor shall provide all tiers of Help Desk support for all system issues for the solution users, program office, and VA system administrators. On a call-back basis, the Contractor shall provide a central point of contact for system and end-user related problems submitted via email, telephone, and/or voice mail.

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

The Help Desk shall be staffed from 8 AM Eastern Standard Time (EST) to 5 PM EST on all federal workdays. Additionally, the Help Desk shall provide email support from 5 PM to 8 PM EST. The Contractor shall respond to Help Desk calls within 15 minutes by telephone, and within 30 minutes by email between 5 PM - 8 PM EST. During times when budget reviews are not occurring, the Contractor shall respond to database downtime issues within one working hour, and on-going database support within eight working hours. Work includes answering questions on and resolving programming errors, updating, and maintaining reference tables, network problems, user access, password reset, and creating reports.

The Contractor shall provide a Help Desk Coverage Plan that details how the Contractor will meet the Help Desk requirements. For historical purposes, this activity required approximately four thousand six hundred (4,600) hours per year in the current system. The Contractor shall provide a description of help desk actions, number of help desk inquiries by type, average and extreme times dedicated to resolution, number of unresolved actions, and risks to the help desk program in the Monthly Progress Report.

Deliverable:

- A. Help Desk Coverage Plan
- B. Toll-Free Help Desk Phone Number

5.2.9 OPERATIONS AND MAINTENANCE DAILY SUPPORT

The Contractor shall provide the following operations and maintenance services for the solution:

1. Maintain the operational availability of the SaaS.
2. Maintain the security of the SaaS.
3. Maintain SaaS application administration data.

The Contractor shall maintain the operational application, including troubleshooting of all aspects of the SaaS applications, database, and supporting infrastructure to determine the causes of any application errors or degradation of systems performance. The Contractor shall also maintain operational coordination with VA entities which provide server and network support for the SaaS infrastructure, as directed by the COR. The Contractor shall assist VA with contingency planning and testing activities for the SaaS.

The Contractor shall maintain the configuration of the application for operation on VA servers and maintain the security of the operational application. The Contractor shall identify and communicate in writing via email to the COR any infrastructure updates or changes which are necessary to comply with VA security requirements identified in VA Directive 6500, such as installation of database or operating system patches. The Contractor shall submit a summary of communications in the Monthly Progress Report.

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

The Contractor shall support the SaaS application data administration operations and maintenance functions including:

1. Application administration and maintenance.
2. Accounting code integrity maintenance.
3. Software platform maintenance.
4. Annual and ad hoc updates to accounting codes, organization structure, and other project and programmatic identification constructs.
5. Database and application testing following updates to SaaS data. The Contractor shall document maintenance activities and unresolved issues in the Monthly Progress Report.

Deliverables:

- A. Summary of Communications (included in the Monthly Progress Report)

5.2.10 TESTING

The Contractor shall plan and test all software development and releases to ensure a quality product. Testing shall include user testing, code testing, and interoperability testing. The Contractor shall establish a test data set (TDS) and testing procedure for use in testing all changes to the system during preparation for system modification releases. The TDS and related procedures shall be used to assure that system processing provides accurate results.

- The Contractor shall document test cases to account for the scope and breadth of functionality being tested. Test results of each test case shall also be documented.
- The Contractor shall provide the test plan, test data set, test cases, and test results as a part of the Monthly Progress Report

Deliverables:

- A. Test Result Report (included in the Monthly Progress Report)

5.2.11 SECURITY

The Contractor shall ensure the solution meets the following security requirements:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA) and have a current VA authorization.
2. The Contractor shall comply with FedRAMP Moderate requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The Contractor shall, where applicable, assist with the VA ATO Sustainment Process to help maintain health and quality of agency authorization of the cloud service or migrated application.

Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832

4. The Contractor shall provide access to FedRAMP authorized and VA authorized environment.
5. The Contractor shall afford VA access to the Contractor's and Cloud Service Provider's (CSP) facilities, installations, technical capabilities, operations, documentation, records, and databases.
6. If new or unanticipated threats or hazards are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall immediately bring the situation to the attention of the other party in accordance with the security addendum B.
7. The Contractor shall not release any data without the consent of VA in writing. All requests for release must be submitted in writing to the Contracting Officer's Representative (COR)/Contracting Officer (CO)
8. For live VA data to be used in this system, access must be provided to the FedRAMP Authorized and Agency Authorized environment.
9. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings.
10. The Contractor shall participate monitoring and reoccurring security artifacts, including monthly POAM reports.

To qualify as SaaS for use at VA, and to align with Federal Risk and Authorization Management Program (FedRAMP) requirements, the hosting for the offering must conform to the NIST 800-145 definition of Cloud Computing and thus contain following key characteristics:

- On-Demand Self-Service: The CSP fully automates the provisioning of both the customer interface and the underlying cloud components of the SaaS offering.
- Broad Network Access: The SaaS capabilities are available over the internet or over a network that is available from all access points the CSC requires. The SaaS offering is accessible through common platforms (e.g., mobile phones, tablets, laptops, and workstations).
- Resource Pooling: The computing infrastructure supporting the SaaS offering is shared among more than one CSC using a multi-tenant model, and resources are dynamically assigned depending on customer demand.
- Rapid Elasticity: Computing capabilities are automatically provisioned and released in a manner that scales with customer demand. In some cases, the scaling of resources may not be fully automated, but it should be fast enough to support the needs of the CSC, which the CSC would have to define.
- Measured Service: Resource usage, such as storage, processing, bandwidth, and user activity are measured and reported on in a manner that is relevant to the SaaS offering.
- The SaaS offering must be hosted within the United States and data stored/processed/transmitted within the offering must remain within the United States. CSPs should be aware of FedRAMP and ready to partner with VA through the SaaS FedRAMP Authorization process.

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

5.2.12 TECHNICAL DOCUMENTATION

The Contractor shall provide an updated Technical Documentation Package to the COR or designee as changes are made to the system. The Technical Documentation Package includes:

1. User System Administrator Manual updates, detailing responsibilities, data, and processes required for a business subject matter expert to administer user access, organization and budget values and hierarchy relationships.
2. Technical System Administration Manual updates, detailing system structures, software tools and components, and maintenance requirements, processes, and schedules.
3. Process flow charts describing the business processes supported by the application.
4. Entity relationship diagrams documenting the database structure and contents.
5. Data element dictionary, listing and describing the data elements contained in the application.
6. Software Version Description.
7. Software Requirements Specification Document (RSD).
8. System Design Document (SDD).
9. Discrepancy Report Summary (DR).
10. Engineering Change Proposal Database (ECP).
11. Concept of Operations Contract Number: X Task Order Number: X.
12. Reference Data Tables Document and formatted report.
13. User Manual.
14. Executive User Manual.
15. Business Administrator User Guide.
16. User Training Manual.
17. User Quick Reference Guide.
18. User Training Computer Based Training (CBT).
19. Executive Training Manual.
20. Executive Training CBT.
21. Customer Acceptance Form.
22. Source Code with unlimited access rights in all development and production environments.

Deliverables:

- A. Technical Documentation Package

6.0 GENERAL REQUIREMENTS

6.1 ENTERPRISE AND IT FRAMEWORK

6.1.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall support the VA enterprise management framework. In association with the framework, the Contractor shall comply with OIT Technical Reference Model

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

(VA TRM). The VA TRM is one component within the overall Enterprise Architecture (EA) that establishes a common vocabulary and structure for describing the information technology used to develop, operate, and maintain enterprise applications. Moreover, the VA TRM, which includes the Standards Profile and Product List, serves as a technology roadmap and tool for supporting OIT. Architecture & Engineering Services (AES) has overall responsibility for the VA TRM.

6.1.2 FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)

The Contractor shall ensure Commercial Off-The-Shelf (COTS) product(s), software configuration and customization, and/or new software are Personal Identity Verification (PIV) card-enabled by accepting HSPD-12 PIV credentials using VA Enterprise Technical Architecture (ETA), https://www.ea.oit.va.gov/EAOIT/VA_EA/Enterprise_Technical_Architecture.asp, and VA Identity and Access Management (IAM) approved enterprise design and integration patterns, <https://www.oit.va.gov/library/recurring/edp/index.cfm>. The Contractor shall ensure all Contractor delivered applications and systems comply with the VA Identity, Credential, and Access Management policies and guidelines set forth in VA Handbook 6510 VA Identity and Access Management, VA Handbook 0735 Homeland Security Presidential Directive 12 (HSPD-12) Program, and align with the Federal Identity, Credential, and Access Management Roadmap and Implementation Guidance v2.0.

The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-63-3, VA Handbook 6500 Appendix F, "VA System Security Controls", and VA IAM enterprise requirements for direct, assertion-based authentication, and/or trust based authentication, as determined by the design and integration patterns. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV card and/or Common Access Card (CAC), as determined by the business need.

The Contractor shall ensure all Contractor delivered applications and systems conform to the specific Identity and Access Management PIV requirements set forth in the Office of Management and Budget (OMB) Memoranda M-05-24, M-19-17, and NIST Federal Information Processing Standard (FIPS) 201-2. OMB Memoranda M-05-24 and M-19-17 can be found at: <https://www.whitehouse.gov/sites/whitehouse.gov/files/omb/memoranda/2005/m05-24.pdf>, and <https://www.whitehouse.gov/wp-content/uploads/2019/05/M-19-17.pdf> respectively. Contractor delivered applications and systems shall be on the FIPS 201-2 Approved Product List (APL). If the Contractor delivered application and system is not on the APL, the Contractor shall be responsible for taking the application and system through the FIPS 201 Evaluation Program.

The Contractor shall ensure all Contractor delivered applications and systems support:

1. Automated provisioning and can use enterprise provisioning service.

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

2. Interfacing with VA's Master Person Index (MPI) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
3. The VA defined unique identity (Secure Identifier [SEC ID] / Integrated Control Number [ICN]).
4. Multiple authenticators for a given identity and authenticators at every Authenticator Assurance Level (AAL) appropriate for the solution.
5. Identity proofing for each Identity Assurance Level (IAL) appropriate for the solution.
6. Federation for each Federation Assurance Level (FAL) appropriate for the solution, if applicable.
7. Two-factor authentication (2FA) through an applicable design pattern as outlined in VA Enterprise Design Patterns.
8. A Security Assertion Markup Language (SAML) implementation if the solution relies on assertion-based authentication. Additional assertion implementations, besides the required SAML assertion, may be provided as long as they are compliant with NIST SP 800-63-3 guidelines.
9. Authentication/account binding based on trusted Hypertext Transfer Protocol (HTTP) headers if the solution relies on Trust based authentication.
10. Role Based Access Control.
11. Auditing and reporting capabilities.
12. Compliance with VIEWS 00155984, PIV Logical Access Policy Clarification <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896>.

The required Assurance Levels for this specific effort are Identity Assurance Level 3, Authenticator Assurance Level 3, and Federation Assurance Level 3.

6.1.3 INTERNET PROTOCOL VERSION 6 (IPv6)

The Contractor solution shall support Internet Protocol Version 6 (IPv6) based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (<https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>). IPv6 technology, in accordance with the USGv6 Program (<https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1>), NIST Special Publication (SP) 500-267B Revision 1 "USGv6 Profile" (<https://doi.org/10.6028/NIST.SP.500-267Br1>), and NIST SP 800-119 "Guidelines for the Secure Deployment of IPv6" (<https://doi.org/10.6028/NIST.SP.800-119>), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices shall support native IPv6 and dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g. web, email, DNS, ISP services, etc.) shall support native IPv6 and dual stack (IPv6 / IPv4) users and all internal infrastructure and applications shall communicate using native IPv6 and dual stack (IPv6 / IPv4) operations.

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

6.1.4 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative" (<https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf>), VA Directive 6513 "Secure External Connections", and shall comply with the TIC 3.0 Core Guidance Documents, including all Volumes and TIC Use Cases, found at the Cybersecurity & Infrastructure Security Agency (CISA) (<https://www.cisa.gov/publication/tic-30-core-guidance-documents>). Any deviations must be approved by the VA TIC 3.0 Working Group at vaoisesatic30team@va.gov.

6.1.5 STANDARD COMPUTER CONFIGURATION

The Contractor IT end user solution that is developed for use on standard VA computers shall be compatible with and be supported on the standard VA operating system, currently Windows 10 (64bit), Edge (Chromium based), and 365 Apps for enterprise. Applications delivered to VA and intended to be deployed to Windows 10 workstations shall be delivered as a signed .msi package with switches for silent and unattended installation and updates shall be delivered in signed .msp file formats for easy deployment using Microsoft Endpoint Configuration Manager (CM) VA's current desktop application deployment tool. Signing of the software code shall be through a vendor provided certificate that is trusted by VA using a code signing authority such as Verizon/Cybertrust or Symantec/VeriSign. The Contractor shall also ensure and certify that their solution functions as expected when used from a standard VA computer, with non-admin, standard user rights that have been configured using the United States Government Configuration Baseline (USGCB) and Defense Information Systems Agency (DISA) Secure Technical Implementation Guide (STIG) specific to the client operating system being used.

6.1.6 VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)

The Contractor shall support VA efforts IAW the updated Veteran Focused Integration Process (VIP) and Product Line Management (PLM). The major focus of the new VIP is on Governance and Reporting and is less prescriptive, with a focus on outcomes and continuous delivery of value. Product Line Management (PLM) is a framework that focuses on delivering functional products that provide the highest priority work to customers while delivering simplified, reliable, and practical solutions to the business, medical staff, and our Veterans. The VIP Guide is a companion guide to the PLM Playbook and can be found at: <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371> and the PLM Playbook can be found at <https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946>. The PLM Playbook pivots from project-centric to product-centric delivery and contains

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

descriptive practices that focuses on outcomes. The PLM Playbook contains a set of “plays” that implement Development, Security, and Operations (DevSecOps) principles and processes such as automated development, continuous integration/continuous delivery, and release on demand. The PLM Playbook details how product lines implement Lean-Agile principles, methods, practices, and techniques through levels of maturity. VIP and PLM are the authoritative processes that IT projects must follow to ensure development and delivery of IT products.

6.1.7 PROCESS ASSET LIBRARY (PAL)

The Contractor shall perform their duties consistent with the processes defined in the OIT Process Asset Library (PAL). The PAL scope includes the full spectrum of OIT functions and activities, such as VIP project management, operations, service delivery, communications, acquisition, and resource management. PAL serves as an authoritative and informative repository of searchable processes, activities or tasks, roles, artifacts, tools and applicable standards and guides to assist the OIT workforce, Government and Contractor personnel. The Contractor shall follow the PAL processes to ensure compliance with policies and regulations and to meet VA quality standards. The PAL includes the contractor onboarding process consistent with Section 6.2.2 and can be found at https://www.va.gov/PROCESS/artifacts/maps/process_CONB_ext.pdf. The main PAL can be accessed at www.va.gov/process.

6.1.8 SOFTWARE AND LICENSING REQUIREMENTS

The Contractor shall be responsible for the provision of all software licenses and any associated licensing maintenance required for any development, delivery, integration, operation, and/or maintenance associated with its proposed application(s), software products, software solution, and/or system including, but not limited to, any and all application(s), software and/or software products that comprise, are a part of, or integrate with the Contractor’s proposed application(s), software products, software solution, and/or system for the life of any resulting contract.

6.2 SECURITY AND PRIVACY REQUIREMENTS

6.2.1 POSITION/TASK RISK DESIGNATION LEVEL(S)

In accordance with VA Handbook 0710, Personnel Security and Suitability Program, the position sensitivity, and the level of background investigation commensurate with the required level of access for the following tasks within the PWS are:

Position Sensitivity and Background Investigation Requirements by Task

Task Number	Tier1 / Low Risk	Tier 2 / Moderate Risk	Tier 4 / High Risk
5.1	☒	☐	☐
5.2	☒	☐	☐
5.3	☒	☐	☐

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

The Tasks identified above, and the resulting Position Sensitivity and Background Investigation requirements identify, in effect, the Background Investigation requirements for Contractor individuals, based upon the tasks the particular Contractor individual will be working. The submitted Contractor Staff Roster must indicate the required Background Investigation Level for each Contractor individual based upon the tasks the Contractor individual will be working, in accordance with their submitted proposal.

6.2.2 CONTRACTOR PERSONNEL SECURITY REQUIREMENTS

Contractor Responsibilities:

- a. The Contractor shall prescreen all personnel requiring access to the computer systems to ensure they maintain the appropriate Background Investigation, and are able to read, write, speak, and understand the English language.
- b. Within 3 business days after award, the Contractor shall provide a roster of Contractor and Subcontractor employees to the COR to begin their background investigations in accordance with the PAL template artifact. The Contractor Staff Roster shall contain the Contractor's Full Name, Date of Birth, Place of Birth, individual background investigation level requirement (based upon Section 6.2 Tasks), etc. The Contractor shall submit full Social Security Numbers either within the Contractor Staff Roster or under separate cover to the COR. The Contractor Staff Roster shall be updated and provided to VA within 1 day of any changes in employee status, training certification completion status, Background Investigation level status, additions/removal of employees, etc. throughout the Period of Performance. The Contractor Staff Roster shall remain a historical document indicating all past information and the Contractor shall indicate in the Comment field, employees no longer supporting this contract. The preferred method to send the Contractor Staff Roster or Social Security Number is by encrypted e-mail. If unable to send encrypted e-mail, other methods which comply with FIPS 140-2 are to encrypt the file, use a secure fax, or use a traceable mail service.
- c. The Contractor should coordinate with the location of the nearest VA fingerprinting office through the COR. Only electronic fingerprints are authorized. The Contractor shall bring their completed Security and Investigations Center (SIC) Fingerprint request form with them (see paragraph d.4. below) when getting fingerprints taken.
- d. The Contractor shall ensure the following required forms are submitted to the COR within 5 days after contract award:
 - 1) Optional Form 306
 - 2) Self-Certification of Continuous Service
 - 3) VA Form 0710
 - 4) Completed SIC Fingerprint Request Form
- e. The Contractor personnel shall submit all required information related to their background investigations (completion of the investigation documents (SF85, SF85P, or SF 86) utilizing the Office of Personnel Management's (OPM)

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

Electronic Questionnaire for Investigations Processing (e-QIP) after receiving an email notification from the Security and Investigation Center (SIC).

- f. The Contractor employee shall certify and release the e-QIP document, print, and sign the signature pages, and send them encrypted to the COR for electronic submission to the SIC. These documents shall be submitted to the COR within 3 business days of receipt of the e-QIP notification email. (Note: OPM is moving towards a “click to sign” process. If click to sign is used, the Contractor employee should notify the COR within 3 business days that documents were signed via e-QIP).
- g. The Contractor shall be responsible for the actions of all personnel provided to work for VA under this contract. In the event that damages arise from work performed by Contractor provided personnel, under the auspices of this contract, the Contractor shall be responsible for all resources necessary to remedy the incident.
- h. A Contractor may be granted unescorted access to VA facilities and/or access to VA Information Technology resources (network and/or protected data) with a favorably adjudicated Special Agreement Check (SAC), completed training delineated in VA Handbook 6500.6 (Appendix C, Section 9), signed “Contractor Rules of Behavior”, and with a valid, operational PIV credential for PIV-only logical access to VA’s network. A PIV card credential can be issued once your SAC has been favorably adjudicated and your background investigation has been scheduled by OPM. However, the Contractor will be responsible for the actions of the Contractor personnel they provide to perform work for VA. The investigative history for Contractor personnel working under this contract must be maintained in the database of OPM.
- i. The Contractor, when notified of an unfavorably adjudicated background investigation on a Contractor employee as determined by the Government, shall withdraw the employee from consideration in working under the contract.
- j. Failure to comply with the Contractor personnel security investigative requirements may result in loss of physical and/or logical access to VA facilities and systems by Contractor and Subcontractor employees and/or termination of the contract for default.
- k. Identity Credential Holders must follow all HSPD-12 policies and procedures as well as use and protect their assigned identity credentials in accordance with VA policies and procedures, displaying their badges at all times, and returning the identity credentials upon termination of their relationship with VA.

Deliverable:

- A. Contractor Staff Roster

6.3 METHOD AND DISTRIBUTION OF DELIVERABLES

The Contractor shall deliver documentation in electronic format, unless otherwise directed in Section B of the solicitation/contract. Acceptable electronic media include:

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

Microsoft 365, MS Word 2000/2003/2007/2010/2019, MS Excel 2000/2003/2007/2010/2019, MS PowerPoint 2000/2003/2007/2010/2019, MS Project 2000/2003/2007/2010/2019, MS Access 2000/2003/2007/2010, MS Visio 2000/2002/2003/2007/2010/2019, AutoCAD 2002/2004/2007/2010, and Adobe Postscript Data Format (PDF).

6.4 PERFORMANCE METRICS

The table below defines the Performance Standards and Acceptable Levels of Performance associated with this effort.

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

Performance Objective	Performance Standard	Acceptable Levels of Performance
A. Technical / Quality of Product or Service	1. Demonstrates understanding of requirements 2. Efficient and effective in meeting requirements 3. Meets technical needs and mission requirements 4. Provides quality services/products 5. Incorporates "ease of use" Human Centered Design principles in any software developed.	Satisfactory or higher
B. Project Milestones and Schedule	1. Established milestones and project dates are met 2. Products completed, reviewed, delivered in accordance with the established schedule 3. Notifies customer in advance of potential problems	Satisfactory or higher
C. Cost & Staffing	1. Currency of expertise and staffing levels appropriate to perform tasks required 2. Personnel possess necessary knowledge, skills, and abilities to perform tasks	Satisfactory or higher
D. Management	1. Integration and coordination of all activities to execute effort	Satisfactory or higher

The COR will utilize a Quality Assurance Surveillance Plan (QASP) throughout the life of the contract to ensure that the Contractor is performing the services required by this PWS in an acceptable level of performance. The Government reserves the right to alter or change the surveillance methods in the QASP at its own discretion. A Performance Based Service Assessment will be used by the COR in accordance with the QASP to assess Contractor performance.

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

6.5 FACILITY/RESOURCE PROVISIONS

The Government will provide office space, telephone service and system access when authorized contract staff work at a Government location as required in order to accomplish the Tasks associated with this PWS. All procedural guides, reference materials, and program documentation for the project and other Government applications will also be provided on an as-needed basis.

The Contractor shall request other Government documentation deemed pertinent to the work accomplishment directly from the Government officials with whom the Contractor has contact. The Contractor shall consider the COR as the final source for needed Government documentation when the Contractor fails to secure the documents by other means. The Contractor is expected to use common knowledge and resourcefulness in securing all other reference materials, standard industry publications, and related materials that are pertinent to the work.

VA may provide remote access to VA specific systems/network in accordance with VA Handbook 6500, which requires the use of a VA approved method to connect external equipment/systems to VA's network. Citrix Access Gateway (CAG) is the current and only VA approved method for remote access users when using or manipulating VA information for official VA Business. VA permits CAG remote access through approved Personally Owned Equipment (POE) and Other Equipment (OE) provided the equipment meets all applicable 6500 Handbook requirements for POE/OE. All of the security controls required for Government furnished equipment (GFE) must be utilized in approved POE or OE. The Contractor shall provide proof to the COR for review and approval that their POE or OE meets the VA Handbook 6500 requirements and VA Handbook 6500.6 Appendix C, herein incorporated as Addendum B, before use. CAG authorized users shall not be permitted to copy, print, or save any VA information accessed via CAG at any time. VA prohibits remote access to VA's network from non-North Atlantic Treaty Organization (NATO) countries. The exception to this are countries where VA has approved operations established (e.g. Philippines and South Korea). Exceptions are determined by the COR in coordination with the Information Security Officer (ISO) and Privacy Officer (PO).

This remote access may provide access to VA specific software such as Veterans Health Information System and Technology Architecture (VistA), ClearQuest, PAL, Primavera, and Remedy, including appropriate seat management and user licenses, depending upon the level of access granted. The Contractor shall utilize government-provided software development and test accounts, documents, and requirements repositories, etc. as required for the development, storage, maintenance, and delivery of products within the scope of this effort. The Contractor shall not transmit, store, or otherwise maintain sensitive data or products in Contractor systems (or media) within the VA firewall IAW VA Handbook 6500.6 dated March 12, 2010. All VA sensitive information shall be protected at all times in accordance with VA Handbook 6500, local security field office System Security Plans (SSP's) and Authority to Operate (ATO)'s for all systems/LAN's accessed while performing the tasks detailed in this PWS. The Contractor shall ensure all work is performed in countries deemed not to pose a

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

significant security risk. For detailed Security and Privacy Requirements (additional requirements of the contract consolidated into an addendum for easy reference) refer to ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED and ADDENDUM B - VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE.

6.6 GOVERNMENT FURNISHED PROPERTY

The Government has multiple remote access solutions available to include Citrix Access Gateway (CAG), Site-to-Site Virtual Private Network (VPN), and RESCUE VPN.

The Government's issuance of Government Furnished Equipment (GFE) is limited to Contractor personnel requiring direct access to the network to: development environments; install, configure and run Technical Reference Model (TRM) approved software and tools (e.g., Oracle, Fortify, Eclipse, SoapUI, WebLogic, LoadRunner); upload/download/ manipulate code, run scripts, and apply patches; configure and change system settings; check logs, troubleshoot/debug, and test/QA.

When necessary, the Government will furnish desktops or laptops, for use by the Contractor to access VA networks, systems, or applications to meet the requirements of this PWS. The overarching goal is to determine the most cost-effective approach to providing needed access to the VA environment coupled with the need to ensure proper Change Management principles are followed. Contractor personnel shall adhere to all VA system access requirements for on-site and remote users in accordance with VA standards, local security regulations, policies, and rules of behavior. GFE shall be approved by the COR and Program Manager on a case-by-case basis prior to issuance.

Based upon the Government assessment of remote access solutions and requirements of this effort, the Government estimates that the following GFE will be required by this effort:

1. **TBD** laptops

The Government will not provide IT accessories including but not limited to Mobile Wi-Fi hotspots/wireless access points, additional or specialized keyboards or mice, laptop bags, extra charging cables, extra Personal Identity Verification card readers, peripheral devices, or additional Random Access Memory (RAM). The Contractor is responsible for providing these types of IT accessories in support of this effort as necessary and any VA installation required for these IT accessories shall be coordinated with the COR.

Additionally, the Contractor shall provide a status of all reportable GFE as part of the **Monthly** Status Report as required by PWS paragraph 5.1. For purposes of this report, reportable GFE includes equipment that is furnished by the Government as tangible "personal" property which the Contractor takes possession of, physically leaves a

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

Government facility, and needs to be returned the end of Contractor performance. The following information shall be provided for each piece of GFE:

1. Name of Contractor employee assigned to the GFE
2. Type of Equipment (Make and Model)
3. Tracking Number/Serial Number
4. VA Bar Code
5. Location
6. Value
7. Total Value of Equipment
8. Anticipated Transfer Date to Government
9. Anticipated Transfer Location

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED

A1.0 Cyber and Information Security Requirements for VA IT Services

The Contractor shall ensure adequate LAN/Internet, data, information, and system security in accordance with VA standard operating procedures and standard PWS language, conditions, laws, and regulations. The Contractor's firewall and web server shall meet or exceed VA minimum requirements for security. All VA data shall be protected behind an approved firewall. Any security violations or attempted violations shall be reported to the VA Program Manager and VA Information Security Officer as soon as possible. The Contractor shall follow all applicable VA policies and procedures governing information security, especially those that pertain to assessment and authorization and continuous monitoring

Contractor supplied equipment, PCs of all types, equipment with hard drives, etc. for contract services must meet all security requirements that apply to Government Furnished Equipment (GFE) and Government Owned Equipment (GOE). Security Requirements include: a) VA Approved Encryption Software must be installed on all laptops or mobile devices before placed into operation, b) Bluetooth equipped devices are prohibited within VA; Bluetooth must be permanently disabled or removed from the device, unless the connection uses FIPS 140-2 (or its successor) validated encryption, c) VA approved anti-virus and firewall software, d) Equipment must meet all VA sanitization requirements and procedures before disposal. The COR, CO, the PM, and the Information Security Officer (ISO) must be notified and verify all security requirements have been adhered to.

Each documented initiative under this contract incorporates VA Handbook 6500.6, "Contract Security," March 12, 2010 by reference as though fully set forth therein. The VA Handbook 6500.6, "Contract Security" shall also be included in every related agreement, contract, or order. The VA Handbook 6500.6, Appendix C, is included in this document as Addendum B.

Training requirements: The Contractor shall complete all mandatory training courses on the current VA training site, the VA Talent Management System (TMS) 2.0, and will be tracked therein. The TMS 2.0 may be accessed at <https://www.tms.va.gov/SecureAuth35/>. If you do not have a TMS 2.0 profile, go to <https://www.tms.va.gov/SecureAuth35/> and click on the "Create New User" link on the TMS 2.0 to gain access.

Contractor employees shall complete a VA Systems Access Agreement if they are provided access privileges as an authorized user of the computer system of VA.

A2.0 VA Enterprise Architecture Compliance

The applications, supplies, and services furnished under this contract must comply with VA Enterprise Architecture (EA), available at <http://www.ea.oit.va.gov/index.asp> in force at the time of issuance of this contract, including the Program Management Plan and

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

VA's rules, standards, and guidelines in the Technical Reference Model/Standards Profile (TRMSP). VA reserves the right to assess contract deliverables for EA compliance prior to acceptance.

A2.1. VA Internet and Intranet Standards

The Contractor shall adhere to and comply with VA Directive 6102 and VA Handbook 6102, Internet/Intranet Services, including applicable amendments and changes, if the Contractor's work includes managing, maintaining, establishing, and presenting information on VA's Internet/Intranet Service Sites. This pertains, but is not limited to: creating announcements; collecting information; databases to be accessed, graphics and links to external sites.

Internet/Intranet Services Directive 6102 is posted at (copy and paste the following URL to browser): https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1056&FType=2

Internet/Intranet Services Handbook 6102 is posted at (copy and paste following URL to browser): https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1055&FType=2

A3.0 Notice of the Federal Accessibility Law Affecting All Information and Communication Technology (ICT) Procurements (Section 508)

On January 18, 2017, the Architectural and Transportation Barriers Compliance Board (Access Board) revised and updated, in a single rulemaking, standards for electronic and information technology developed, procured, maintained, or used by Federal agencies covered by Section 508 of the Rehabilitation Act of 1973, as well as our guidelines for telecommunications equipment and customer premises equipment covered by Section 255 of the Communications Act of 1934. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

A3.1. Section 508 – Information and Communication Technology (ICT) Standards

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: <https://www.access-board.gov/guidelines-and-standards/communications-and-it/about-the-ict-refresh/final-rule/text-of-the-standards-and-guidelines>. A printed copy of the standards will be supplied upon request.

Federal agencies must comply with the updated Section 508 Standards beginning on January 18, 2018. The Final Rule as published in the Federal Register is available from the Access Board: <https://www.access-board.gov/guidelines-and-standards/communications-and-it/about-the-ict-refresh/final-rule>.

Budget and Acquisition Management (SaaS) Solution and Maintenance VA-25-00054832

The Contractor shall comply with “508 Chapter 2: Scoping Requirements” for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☒ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

A3.2. Compatibility with Assistive Technology

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

A3.3. Acceptance and Acceptance Testing

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of the Section 508 Chapter 2: Scoping Requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

A4.0 Physical Security & Safety Requirements:

The Contractor and their personnel shall follow all VA policies, standard operating procedures, applicable laws and regulations while on VA property. Violations of VA regulations and policies may result in citation and disciplinary measures for persons violating the law.

1. The Contractor and their personnel shall wear visible identification at all times while they are on the premises.
2. VA does not provide parking spaces at the work site; the Contractor must obtain parking at the work site if needed. It is the responsibility of the Contractor to park in the appropriate designated parking areas. VA will not invalidate or make reimbursement for parking violations of the Contractor under any conditions.
3. Smoking is prohibited inside/outside any building other than the designated smoking areas.

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

4. Possession of weapons is prohibited.
5. The Contractor shall obtain all necessary licenses and/or permits required to perform the work, with the exception of software licenses that need to be procured from a Contractor or vendor in accordance with the requirements document. The Contractor shall take all reasonable precautions necessary to protect persons and property from injury or damage during the performance of this contract.

A5.0 Confidentiality and Non-Disclosure

The Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations.

The Contractor may have access to Protected Health Information (PHI) and Electronic Protected Health Information (EPHI) that is subject to protection under the regulations issued by the Department of Health and Human Services, as mandated by the Health Insurance Portability and Accountability Act of 1996 (HIPAA); 45 CFR Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information ("Privacy Rule"); and 45 CFR Parts 160 and 164, Subparts A and C, the Security Standard ("Security Rule"). Pursuant to the Privacy and Security Rules, the Contractor must agree in writing to certain mandatory provisions regarding the use and disclosure of PHI and EPHI.

1. The Contractor will have access to some privileged and confidential materials of VA. These printed and electronic documents are for internal use only, are not to be copied or released without permission, and remain the sole property of VA. Some of these materials are protected by the Privacy Act of 1974 (revised by PL 93-5791) and Title 38. Unauthorized disclosure of Privacy Act or Title 38 covered materials is a criminal offense.
2. The VA CO will be the sole authorized official to release in writing, any data, draft deliverables, final deliverables, or any other written or printed materials pertaining to this contract. The Contractor shall release no information. Any request for information relating to this contract presented to the Contractor shall be submitted to the VA CO for response.
3. Contractor personnel recognize that in the performance of this effort, Contractor personnel may receive or have access to sensitive information, including information provided on a proprietary basis by carriers, equipment manufacturers and other private or public entities. Contractor personnel agree to safeguard such information and use the information exclusively in the performance of this contract. Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations as enumerated in this section and elsewhere in this Contract and its subparts and appendices.
4. Contractor shall limit access to the minimum number of personnel necessary for contract performance for all information considered sensitive or proprietary in nature. If the Contractor is uncertain of the sensitivity of any information obtained during the performance this contract, the Contractor has a responsibility to ask the VA CO.

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

5. Contractor shall train all of their employees involved in the performance of this contract on their roles and responsibilities for proper handling and nondisclosure of sensitive VA or proprietary information. Contractor personnel shall not engage in any other action, venture or employment wherein sensitive information shall be used for the profit of any party other than those furnishing the information. The sensitive information transferred, generated, transmitted, or stored herein is for VA benefit and ownership alone.
6. Contractor shall maintain physical security at all facilities housing the activities performed under this contract, including any Contractor facilities according to VA-approved guidelines and directives. The Contractor shall ensure that security procedures are defined and enforced to ensure all personnel who are provided access to patient data must comply with published procedures to protect the privacy and confidentiality of such information as required by VA.
7. Contractor must adhere to the following:
 - a. The use of "thumb drives" or any other medium for transport of information is expressly prohibited.
 - b. Controlled access to system and security software and documentation.
 - c. Recording, monitoring, and control of passwords and privileges.
 - d. All terminated personnel are denied physical and electronic access to all data, program listings, data processing equipment and systems.
 - e. VA, as well as any Contractor (or Subcontractor) systems used to support development, provide the capability to cancel immediately all access privileges and authorizations upon employee termination.
 - f. Contractor PM and VA PM are informed within twenty-four (24) hours of any employee termination.
 - g. Acquisition sensitive information shall be marked "Acquisition Sensitive" and shall be handled as "For Official Use Only (FOUO)".
 - h. Contractor does not require access to classified data.
8. Regulatory standard of conduct governs all personnel directly and indirectly involved in procurements. All personnel engaged in procurement and related activities shall conduct business in a manner above reproach and, except as authorized by statute or regulation, with complete impartiality and with preferential treatment for none. The general rule is to strictly avoid any conflict of interest or even the appearance of a conflict of interest in VA/Contractor relationships.
9. VA Form 0752 shall be completed by all Contractor employees working on this contract, and shall be provided to the CO before any work is performed. In the case that Contractor personnel are replaced in the future, their replacements shall complete VA Form 0752 prior to beginning work.

A6.0 INFORMATION TECHNOLOGY USING ENERGY-EFFICIENT PRODUCTS

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

The Contractor shall comply with Sections 524 and Sections 525 of the Energy Independence and Security Act of 2007; Section 104 of the Energy Policy Act of 2005; Executive Order 13834, "Efficient Federal Operations", dated May 17, 2018; Executive Order 13221, "Energy-Efficient Standby Power Devices," dated August 2, 2001; and the Federal Acquisition Regulation (FAR) to provide ENERGY STAR®, Federal Energy Management Program (FEMP) designated, and Electronic Product Environmental Assessment Tool (EPEAT) registered products in providing information technology products and/or services.

A6.1. EPEAT

EPEAT product compliance is not required in this acquisition.

A6.2. ENERGY STAR

Energy Star product compliance is not required in this acquisition.

A6.3. FEMP

FEMP or FEMP low standby power product compliance is not required in this acquisition.

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

**ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM
SECURITY/PRIVACY LANGUAGE**

APPLICABLE PARAGRAPHS TAILORED FROM: *THE VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE, VA HANDBOOK 6500.6, APPENDIX C, MARCH 12, 2010*

B1. GENERAL

Contractors, Contractor personnel, Subcontractors, and Subcontractor personnel shall be subject to the same Federal laws, regulations, standards, and VA Directives and Handbooks as VA and VA personnel regarding information and information system security.

B2. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

a. A Contractor/Subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees, Subcontractors, and affiliates only to the extent necessary to perform the services specified in the contract, agreement, or task order.

b. All Contractors, Subcontractors, and third-party servicers and associates working with VA information are subject to the same investigative requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for Contractors must be in accordance with VA Directive and Handbook 0710, *Personnel Suitability and Security Program*. The Office for Operations, Security, and Preparedness is responsible for these policies and procedures.

c. Contract personnel who require access to national security programs must have a valid security clearance. National Industrial Security Program (NISP) was established by Executive Order 12829 to ensure that cleared U.S. defense industry contract personnel safeguard the classified information in their possession while performing work on contracts, programs, bids, or research and development efforts. The Department of Veterans Affairs does not have a Memorandum of Agreement with Defense Security Service (DSS). Verification of a Security Clearance must be processed through the Special Security Officer located in the Planning and National Security Service within the Office of Operations, Security, and Preparedness.

d. Custom software development and outsourced operations must be located in the U.S. to the maximum extent practical. If such services are proposed to be performed abroad and are not disallowed by other VA policy or mandates (e.g. Business Associate Agreement, Section 3G), the Contractor/Subcontractor must state where all non-U.S. services are provided and detail a security plan, deemed to be acceptable by VA, specifically to address mitigation of the resulting problems of communication, control, data protection, and so forth. Location within the U.S. may be an evaluation factor.

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

e. The Contractor or Subcontractor must notify the CO immediately when an employee working on a VA system or with access to VA information is reassigned or leaves the Contractor or Subcontractor's employ. The CO must also be notified immediately by the Contractor or Subcontractor prior to an unfriendly termination.

B3. VA INFORMATION CUSTODIAL LANGUAGE

1. Information made available to the Contractor or Subcontractor by VA for the performance or administration of this contract or information developed by the Contractor/Subcontractor in performance or administration of the contract shall be used only for those purposes and shall not be used in any other way without the prior written agreement of VA. This clause expressly limits the Contractor/Subcontractor's rights to use data as described in Rights in Data - General, FAR 52.227-14(d) (1).

2. VA information should not be co-mingled, if possible, with any other data on the Contractors/Subcontractor's information systems or media storage systems in order to ensure VA requirements related to data protection and media sanitization can be met. If co-mingling must be allowed to meet the requirements of the business need, the Contractor must ensure that VA information is returned to VA or destroyed in accordance with VA's sanitization requirements. VA reserves the right to conduct on-site inspections of Contractor and Subcontractor IT resources to ensure data security controls, separation of data and job duties, and destruction/media sanitization procedures are in compliance with VA directive requirements.

3. Prior to termination or completion of this contract, Contractor/Subcontractor must not destroy information received from VA, or gathered/created by the Contractor in the course of performing this contract without prior written approval by VA. Any data destruction done on behalf of VA by a Contractor/Subcontractor must be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, *Records and Information Management* and its Handbook 6300.1 *Records Management Procedures*, applicable VA Records Control Schedules, and VA Handbook 6500.1, *Electronic Media Sanitization*. Self-certification by the Contractor that the data destruction requirements above have been met must be sent to the VA CO within 30 days of termination of the contract.

4. The Contractor/Subcontractor must receive, gather, store, back up, maintain, use, disclose and dispose of VA information only in compliance with the terms of the contract and applicable Federal and VA information confidentiality and security laws, regulations and policies. If Federal or VA information confidentiality and security laws, regulations and policies become applicable to VA information or information systems after execution of the contract, or if NIST issues or updates applicable FIPS or Special Publications (SP) after execution of this contract, the parties agree to negotiate in good faith to implement the information confidentiality and security laws, regulations and policies in this contract.

Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832

5. The Contractor/Subcontractor shall not make copies of VA information except as authorized and necessary to perform the terms of the agreement or to preserve electronic information stored on Contractor/Subcontractor electronic storage media for restoration in case any electronic equipment or data used by the Contractor/Subcontractor needs to be restored to an operating state. If copies are made for restoration purposes, after the restoration is complete, the copies must be appropriately destroyed.

6. If VA determines that the Contractor has violated any of the information confidentiality, privacy, and security provisions of the contract, it shall be sufficient grounds for VA to withhold payment to the Contractor or third party or terminate the contract for default or terminate for cause under Federal Acquisition Regulation (FAR) part 12.

7. If a VHA contract is terminated for cause, the associated Business Associate Agreement (BAA) must also be terminated and appropriate actions taken in accordance with VHA Directive 1605.05, *Business Associate Agreements*. Absent an agreement to use or disclose protected health information, there is no business associate relationship.

8. The Contractor/Subcontractor must store, transport, or transmit VA sensitive information in an encrypted form, using VA-approved encryption tools that are, at a minimum, FIPS 140-2 validated.

9. The Contractor/Subcontractor's firewall and Web services security controls, if applicable, shall meet or exceed VA minimum requirements. VA Configuration Guidelines are available upon request.

10. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor/Subcontractor may use and disclose VA information only in two other situations: (i) in response to a qualifying order of a court of competent jurisdiction, or (ii) with VA prior written approval. The Contractor/Subcontractor must refer all requests for, demands for production of, or inquiries about, VA information and information systems to the VA CO for response.

11. Notwithstanding the provision above, the Contractor/Subcontractor shall not release VA records protected by Title 38 U.S.C. 5705, confidentiality of medical quality assurance records and/or Title 38 U.S.C. 7332, confidentiality of certain health records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse, or infection with human immunodeficiency virus. If the Contractor/Subcontractor is in receipt of a court order or other requests for the above-mentioned information, that Contractor/Subcontractor shall immediately refer such court orders or other requests to the VA CO for response.

12. For service that involves the storage, generating, transmitting, or exchanging of VA sensitive information but does not require Assessment and Authorization (A&A) or a Memorandum of Understanding-Interconnection Security Agreement (MOU-ISA) for

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

system interconnection, the Contractor/Subcontractor must complete a Contractor Security Control Assessment (CSCA) on a yearly basis and provide it to the COR.

B4. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

1. Information systems that are designed or developed for or on behalf of VA at non-VA facilities shall comply with all VA directives developed in accordance with FISMA, HIPAA, NIST, and related VA security and privacy control requirements for Federal information systems. This includes standards for the protection of electronic PHI, outlined in 45 C.F.R. Part 164, Subpart C, information and system security categorization level designations in accordance with FIPS 199 and FIPS 200 with implementation of all baseline security controls commensurate with the FIPS 199 system security categorization (reference VA Handbook 6500, *Risk Management Framework for VA Information Systems – Tier 3: VA Information Security Program*, and the TIC Reference Architecture). During the development cycle a Privacy Impact Assessment (PIA) must be completed, provided to the COR, and approved by the VA Privacy Service in accordance with Directive 6508, *Implementation of Privacy Threshold Analysis and Privacy Impact Assessment*.

2. The Contractor/Subcontractor shall certify to the COR that applications are fully functional and operate correctly as intended on systems using the VA Federal Desktop Core Configuration (FDCC), and the common security configuration guidelines provided by NIST or VA. This includes Internet Explorer 11 configured to operate on Windows 10 and future versions, as required.

3. The standard installation, operation, maintenance, updating, and patching of software shall not alter the configuration settings from the VA approved and FDCC configuration. Information technology staff must also use the Windows Installer Service for installation to the default “program files” directory and silently install and uninstall.

4. Applications designed for normal end users shall run in the standard user context without elevated system administration privileges.

5. The security controls must be designed, developed, approved by VA, and implemented in accordance with the provisions of VA security system development life cycle as outlined in NIST Special Publication 800-37, *Guide for Applying the Risk Management Framework to Federal Information Systems*, VA Handbook 6500, *Risk Management Framework for VA Information Systems – Tier 3: VA Information Security Program* and VA Handbook 6500.5, *Incorporating Security and Privacy in System Development Lifecycle*.

6. The Contractor/Subcontractor is required to design, develop, or operate a System of Records Notice (SOR) on individuals to accomplish an agency function subject to the Privacy Act of 1974, (as amended), Public Law 93-579, December 31,

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

1974 (5 U.S.C. 552a) and applicable agency regulations. Violation of the Privacy Act may involve the imposition of criminal and civil penalties.

7. The Contractor/Subcontractor agrees to:

a. Comply with the Privacy Act of 1974 (the Act) and the agency rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish an agency function when the contract specifically identifies:

i. The Systems of Records (SOR); and

ii. The design, development, or operation work that the Contractor/Subcontractor is to perform;

b. Include the Privacy Act notification contained in this contract in every solicitation and resulting subcontract and in every subcontract awarded without a solicitation, when the work statement in the proposed subcontract requires the redesign, development, or operation of a SOR on individuals that is subject to the Privacy Act; and

c. Include this Privacy Act clause, including this subparagraph (c), in all subcontracts awarded under this contract which requires the design, development, or operation of such a SOR.

8. In the event of violations of the Act, a civil action may be brought against the agency involved when the violation concerns the design, development, or operation of a SOR on individuals to accomplish an agency function, and criminal penalties may be imposed upon the officers or employees of the agency when the violation concerns the operation of a SOR on individuals to accomplish an agency function. For purposes of the Act, when the contract is for the operation of a SOR on individuals to accomplish an agency function, the Contractor/Subcontractor is considered to be an employee of the agency.

a. "Operation of a System of Records" means performance of any of the activities associated with maintaining the SOR, including the collection, use, maintenance, and dissemination of records.

b. "Record" means any item, collection, or grouping of information about an individual that is maintained by an agency, including, but not limited to, education, financial transactions, medical history, and criminal or employment history and contains the person's name, or identifying number, symbol, or any other identifying particular assigned to the individual, such as a fingerprint or voiceprint, or a photograph.

c. "System of Records" means a group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual.

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

9. The vendor shall ensure the security of all procured or developed systems and technologies, including their subcomponents (hereinafter referred to as “Systems”), throughout the life of this contract and any extension, warranty, or maintenance periods. This includes, but is not limited to workarounds, patches, hot fixes, upgrades, and any physical components (hereafter referred to as Security Fixes) which may be necessary to fix all security vulnerabilities published or known to the vendor anywhere in the Systems, including Operating Systems and firmware. The vendor shall ensure that Security Fixes shall not negatively impact the Systems.

10. The vendor shall notify VA within 24 hours of the discovery or disclosure of successful exploits of the vulnerability which can compromise the security of the Systems (including the confidentiality or integrity of its data and operations, or the availability of the system). Such issues shall be remediated as quickly as is practical, *but in no event longer than _____ days.*

11. When the Security Fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the vendor will provide written notice to VA that the patch has been validated as not affecting the Systems within 10 working days. When the vendor is responsible for operations or maintenance of the Systems, they shall apply the Security Fixes *within _____ days.*

12. All other vulnerabilities shall be remediated as specified in this paragraph in a timely manner based on risk, but within 60 days of discovery or disclosure. Exceptions to this paragraph (e.g. for the convenience of VA) shall only be granted with approval of the CO and the VA Assistant Secretary for Office of Information and Technology.

B5. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE, OR USE

a. For information systems that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities, Contractors/Subcontractors are fully responsible and accountable for ensuring compliance with all HIPAA, Privacy Act, FISMA, NIST, FIPS, and VA security and privacy directives and handbooks. This includes conducting compliant risk assessments, routine vulnerability scanning, system patching and change management procedures, and the completion of an acceptable contingency plan for each system. The Contractor’s security control procedures must be equivalent, to those procedures used to secure VA systems. A Privacy Impact Assessment (PIA) must also be provided to the COR and approved by VA Privacy Service prior to operational approval. All external Internet connections to VA network involving VA information must be in accordance with the TIC Reference Architecture and reviewed and approved by VA prior to implementation. For Cloud Services hosting, the Contractor shall also ensure compliance with the Federal Risk and Authorization Management Program (FedRAMP).

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

b. Adequate security controls for collecting, processing, transmitting, and storing of Personally Identifiable Information (PII), as determined by the VA Privacy Service, must be in place, tested, and approved by VA prior to hosting, operation, maintenance, or use of the information system, or systems by or on behalf of VA. These security controls are to be assessed and stated within the PIA and if these controls are determined not to be in place, or inadequate, a Plan of Action and Milestones (POA&M) must be submitted and approved prior to the collection of PII.

c. Outsourcing (Contractor facility, Contractor equipment or Contractor staff) of systems or network operations, telecommunications services, or other managed services requires A&A of the Contractor's systems in accordance with VA Handbook 6500.3, *Assessment, Authorization and Continuous Monitoring of VA Information Systems* and/or the VA OCS Certification Program Office. Government-owned (Government facility or Government equipment) Contractor-operated systems, third party or business partner networks require memorandums of understanding and interconnection security agreements (MOU-ISA) which detail what data types are shared, who has access, and the appropriate level of security controls for all systems connected to VA networks.

d. The Contractor/Subcontractor's system must adhere to all FISMA, FIPS, and NIST standards related to the annual FISMA security controls assessment and review and update the PIA. Any deficiencies noted during this assessment must be provided to the VA CO and the ISO for entry into the VA POA&M management process. The Contractor/Subcontractor must use the VA POA&M process to document planned remedial actions to address any deficiencies in information security policies, procedures, and practices, and the completion of those activities. Security deficiencies must be corrected within the timeframes approved by the Government. Contractor/Subcontractor procedures are subject to periodic, unannounced assessments by VA officials, including the VA Office of Inspector General. The physical security aspects associated with Contractor/Subcontractor activities must also be subject to such assessments. If major changes to the system occur that may affect the privacy or security of the data or the system, the A&A of the system may need to be reviewed, retested and re-authorized per VA Handbook 6500.3. This may require reviewing and updating all of the documentation (PIA, System Security Plan, and Contingency Plan). The Certification Program Office can provide guidance on whether a new A&A would be necessary.

e. The Contractor/Subcontractor must conduct an annual self-assessment on all systems and outsourced services as required. Both hard copy and electronic copies of the assessment must be provided to the COR. The Government reserves the right to conduct such an assessment using Government personnel or another Contractor/Subcontractor. The Contractor/Subcontractor must take appropriate and timely action (this can be specified in the contract) to correct or mitigate any weaknesses discovered during such testing, generally at no additional cost.

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

f. VA prohibits the installation and use of personally owned or Contractor/Subcontractor owned equipment or software on the VA network. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, or contract. All of the security controls required for Government furnished equipment (GFE) must be utilized in approved other equipment (OE) and must be funded by the owner of the equipment. All remote systems must be equipped with, and use, a VA-approved antivirus (AV) software and a personal (host-based or enclave based) firewall that is configured with a VA approved configuration. Software must be kept current, including all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-viral software and the firewall on the non-VA owned OE.

g. All electronic storage media used on non-VA leased or non-VA owned IT equipment that is used to store, process, or access VA information must be handled in adherence with VA Handbook 6500.1, *Electronic Media Sanitization* upon: (i) completion or termination of the contract or (ii) disposal or return of the IT equipment by the Contractor/Subcontractor or any person acting on behalf of the Contractor/Subcontractor, whichever is earlier. Media (hard drives, optical disks, CDs, back-up tapes, etc.) used by the Contractors/Subcontractors that contain VA information must be returned to VA for sanitization or destruction or the Contractor/Subcontractor must self-certify that the media has been disposed of per 6500.1 requirements. This must be completed within 30 days of termination of the contract.

h. Bio-Medical devices and other equipment or systems containing media (hard drives, optical disks, etc.) with VA sensitive information must not be returned to the vendor at the end of lease, for trade-in, or other purposes. The options are:

- 1) Vendor must accept the system without the drive;
- 2) VA's initial medical device purchase includes a spare drive which must be installed in place of the original drive at time of turn-in; or
- 3) VA must reimburse the company for media at a reasonable open market replacement cost at time of purchase.
- 4) Due to the highly specialized and sometimes proprietary hardware and software associated with medical equipment/systems, if it is not possible for VA to retain the hard drive, then;
 - a) The equipment vendor must have an existing BAA if the device being traded in has sensitive information stored on it and hard drive(s) from the system are being returned physically intact; and
 - b) Any fixed hard drive on the device must be non-destructively sanitized to the greatest extent possible without negatively impacting system operation. Selective clearing down to patient data folder level is recommended using VA approved and

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

validated overwriting technologies/methods/tools. Applicable media sanitization specifications need to be preapproved and described in the purchase order or contract.

c) A statement needs to be signed by the Director (System Owner) that states that the drive could not be removed and that (a) and (b) controls above are in place and completed. The ISO needs to maintain the documentation.

B6. SECURITY INCIDENT INVESTIGATION

a. The term “security incident” means an event that has, or could have, resulted in unauthorized access to, loss or damage to VA assets, or sensitive information, or an action that breaches VA security procedures. The Contractor/Subcontractor shall immediately notify the COR and simultaneously, the designated ISO and Privacy Officer for the contract of any known or suspected security/privacy incidents, or any unauthorized disclosure of sensitive information, including that contained in system(s) to which the Contractor/Subcontractor has access.

b. To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor’s notice to VA shall identify the information involved, the circumstances surrounding the incident (including to whom, how, when, and where the VA information or assets were placed at risk or compromised), and any other information that the Contractor/Subcontractor considers relevant.

c. With respect to unsecured protected health information, the business associate is deemed to have discovered a data breach when the business associate knew or should have known of a breach of such information. Upon discovery, the business associate must notify the covered entity of the breach. Notifications need to be made in accordance with the executed business associate agreement.

d. In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG and Security and Law Enforcement. The Contractor, its employees, and its Subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.

B7. LIQUIDATED DAMAGES FOR DATA BREACH

a. Consistent with the requirements of 38 U.S.C. §5725, a contract may require access to sensitive personal information. If so, the Contractor is liable to VA for

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

liquidated damages in the event of a data breach or privacy incident involving any SPI the Contractor/Subcontractor processes or maintains under this contract. However, it is the policy of VA to forgo collection of liquidated damages in the event the Contractor provides payment of actual damages in an amount determined to be adequate by the agency.

b. The Contractor/Subcontractor shall provide notice to VA of a “security incident” as set forth in the Security Incident Investigation section above. Upon such notification, VA must secure from a non-Department entity or the VA Office of Inspector General an independent risk analysis of the data breach to determine the level of risk associated with the data breach for the potential misuse of any sensitive personal information involved in the data breach. The term 'data breach' means the loss, theft, or other unauthorized access, or any access other than that incidental to the scope of employment, to data containing sensitive personal information, in electronic or printed form, that results in the potential compromise of the confidentiality or integrity of the data. Contractor shall fully cooperate with the entity performing the risk analysis. Failure to cooperate may be deemed a material breach and grounds for contract termination.

c. Each risk analysis shall address all relevant information concerning the data breach, including the following:

- 1) Nature of the event (loss, theft, unauthorized access);
- 2) Description of the event, including:
 - a) date of occurrence;
 - b) data elements involved, including any PII, such as full name, social security number, date of birth, home address, account number, disability code;
- 3) Number of individuals affected or potentially affected;
- 4) Names of individuals or groups affected or potentially affected;
- 5) Ease of logical data access to the lost, stolen or improperly accessed data in light of the degree of protection for the data, e.g., unencrypted, plain text;
- 6) Amount of time the data has been out of VA control;
- 7) The likelihood that the sensitive personal information will or has been compromised (made accessible to and usable by unauthorized persons);
- 8) Known misuses of data containing sensitive personal information, if any;
- 9) Assessment of the potential harm to the affected individuals;

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

10) Data breach analysis as outlined in 6500.2 Handbook, *Management of Breaches Involving Sensitive Personal Information*, as appropriate; and

11) Whether credit protection services may assist record subjects in avoiding or mitigating the results of identity theft based on the sensitive personal information that may have been compromised.

d. Based on the determinations of the independent risk analysis, the Contractor shall be responsible for paying to VA liquidated damages in the amount of \$37.50 per affected individual to cover the cost of providing credit protection services to affected individuals consisting of the following:

- 1) Notification;
- 2) One year of credit monitoring services consisting of automatic daily monitoring of at least 3 relevant credit bureau reports;
- 3) Data breach analysis;
- 4) Fraud resolution services, including writing dispute letters, initiating fraud alerts and credit freezes, to assist affected individuals to bring matters to resolution;
- 5) One year of identity theft insurance with \$20,000.00 coverage at \$0 deductible; and
- 6) Necessary legal expenses the subjects may incur to repair falsified or damaged credit records, histories, or financial affairs.

B8. SECURITY CONTROLS COMPLIANCE TESTING

On a periodic basis, VA, including the Office of Inspector General, reserves the right to evaluate any or all of the security controls and privacy practices implemented by the Contractor under the clauses contained within the contract. With 10 working-day's notice, at the request of the Government, the Contractor must fully cooperate and assist in a Government-sponsored security controls assessment at each location wherein VA information is processed or stored, or information systems are developed, operated, maintained, or used on behalf of VA, including those initiated by the Office of Inspector General. The Government may conduct a security control assessment on shorter notice (to include unannounced assessments) as determined by VA in the event of a security incident or at any other time.

B9. TRAINING

- a. All Contractor employees and Subcontractor employees requiring access to VA information and VA information systems shall complete the following before being granted access to VA information and its systems:

**Budget and Acquisition Management (SaaS) Solution and Maintenance
VA-25-00054832**

- 1) Sign and acknowledge (either manually or electronically) understanding of and responsibilities for compliance with the VA Information Security Rules of Behavior, relating to access to VA information and information systems;
 - 2) Successfully complete the VA Privacy and Information Security Awareness and Rules of Behavior course (TMS 2.0 # VA 10176) and complete this required privacy and information security training annually;
 - 3) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system access [to be defined by the VA program official and provided to the CO for inclusion in the solicitation document – e.g., any role-based information security training required in accordance with NIST Special Publication 800-16, Information Technology Security Training Requirements.]
- b. The Contractor shall provide to the CO and/or the COR a copy of the training certificates and certification of signing the Contractor Rules of Behavior for each applicable employee within 2 days of the initiation of the contract and annually thereafter, as required.
- Failure to complete the mandatory annual training and electronically sign the Rules of Behavior annually, within the timeframe required, is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the training and documents are complete.